



Weekly Security & Compliance Report

Platform security posture for the 7-day window ending Jul 31, 2026. Covers Curation supply chain gate activity, Xray vulnerability analysis, and prioritized remediation actions.

Period • Jul 25, 2026 – Jul 31, 2026 Instance • solenglATEST.jfrog.io Generated • 2026-07-31

Schema • 2.0-beta

SECURITY POSTURE AT A GLANCE

500

Critical violations
No prior period

168

Packages blocked
of 27,669 screened

2,144

Total violations
0 high, 0 medium

77%

Xray indexed
846 of 1,094 repos

10

Active developers

82%

Curation coverage

15

Active watches

120

Enforcing policies

Baseline established. Next report will compare against this snapshot.

01 • CURATION

Supply chain gate

Package screening

Clean 27,501

Blocked
168

Dry Run 27,694

8 Malicious (5%) 131 Security (78%) 29 Operational (17%)

27,501

Clean packages allowed
after policy evaluation

0

Requests without
inspection

18

Pending waiver requests

15%

Upgrade-after-block rate

10

active developers using the Curation gate

27,669 package requests screened this period

DEVELOPER	REQUESTS	APPROVED	BLOCKED	BLOCK RATE
shanil	17,801	17,713	88	—
ananthak	3,099	3,099	0	—
rodolphef@jfrog.com	2,351	2,351	0	—
umac@jfrog.com	1,549	1,514	35	2%
jfxsbm@01j15c8zmbb08rywgndaaqjwe8	1,219	1,214	5	—
davidli	983	960	23	2%
maharship	394	389	5	1%
token:tomokim-solenglatest-github-oidc/cocoa-maemae	182	179	3	2%
tomokim@jfrog.com	61	52	9	15%
petrof	30	30	0	—

ECOSYSTEM COVERAGE

npm		72/73
Docker		28/72
HuggingFaceML		42/42
PyPI		31/37
Maven		31/32
AIEditorExtensions		13/15
oci		0/6
NuGet		5/5

POLICY SUMMARY

154 Curation policies registered
120 enforcing (Block action)
27 Dry Run (observe only)
242 of **296** supported remotes connected

Top blocked packages

PACKAGE	ECOSYSTEM	REASON	BLOCKS
<code>cors.js</code>	npm	MALICIOUS	5
<code>abuden2</code>	npm	MALICIOUS	3
<code>ejs</code>	npm	Policy violation	41
<code>lodash</code>	npm	Policy violation	25
<code>axios</code>	npm	Policy violation	7
<code>protobufjs</code>	npm	Policy violation	7
<code>vm2</code>	npm	Policy violation	7
<code>brace-expansion</code>	npm	Policy violation	5
<code>click</code>	PyPI	Policy violation	5
<code>fast-uri</code>	npm	Policy violation	5
<code>commons-fileupload:commons-fileupload</code>	Maven	Policy violation	4
<code>org.apache.logging.log4j:log4j-core</code>	Maven	Policy violation	4
<code>org.apache.struts:struts2-core</code>	Maven	Policy violation	4
<code>tomlkit</code>	PyPI	Policy violation	4
<code>@remix-run/node</code>	npm	Policy violation	3

Protection by policy

POLICY	SCOPE	BLOCKED	CLEAN	BLOCK %	CLEAN %
<code>shani-high-cvss-9</code>	Selected repositories	88	6	93.6%	6.4%
<code>14day-umac-policy</code>	Selected repositories	27	0	100%	0%
<code>tomokim-npm-block-policy-cvss-9-or-above</code>	Selected repositories	12	0	100%	0%
<code>davidli-npm-strict</code>	Selected repositories	10	0	100%	0%
<code>Cvs7-above</code>	Selected repositories	5	0	100%	0%
<code>jml-rsa-demo-pypi</code>	Selected repositories	5	0	100%	0%

POLICY	SCOPE	BLOCKED	CLEAN	BLOCK %	CLEAN %
shani-malicious-packages	Selected repositories	5	0	100%	0%
frogs-npm-malicious-block	Selected repositories	3	0	100%	0%
aged packages	All remote repositories	2	0	100%	0%
AICatalog-020cefcedef68626afb328381d4b90768544860f	Selected repositories	0	0	0%	0%
Block Released less than 30 days	Selected repositories	0	0	0%	0%
Block blockbysecurity Label	Selected repositories	0	0	0%	0%
ak-ide-immature-policy	Selected repositories	0	0	0%	0%
ak-malicious-ide-policy	Selected repositories	0	0	0%	0%
anubhav-high-critical-cve	Selected repositories	0	0	0%	0%
anubhav-immature-policy	Selected repositories	0	0	0%	0%
anubhav-malicious-policy	Selected repositories	0	0	0%	0%
banned-extensions	Selected repositories	0	0	0%	0%
carm-block-malicious	Selected repositories	0	0	0%	0%
carm-npm-critical	Selected repositories	0	0	0%	0%

RECOMMENDED BASELINE

Block malicious org -wide: Missing

No matching policy discovered

CACHED-PACKAGE ENFORCEMENT

29 / 120 blocking policies cover cached packages

Global setting: not exposed

Policies still in Dry Run

POLICY	SCOPE	DAYS IN DRY RUN
block_aged_package_with_newer_version	All remote repositories	73
block_aged_package_without_newer_version	All remote repositories	73
block_cvss_4to7_with_fix_version	All remote repositories	4
block_cvss_4to7_with_or_without_fix_version	All remote repositories	73
block_cvss_7to9_with_fix_version	All remote repositories	73
block_cvss_7to9_with_or_without_fix_version	All remote repositories	73
block_cvss_9to10_with_fix_version	All remote repositories	73
block_cvss_9to10_with_or_without_fix_version	All remote repositories	73
block_image_not_offical_docker_hub	All remote repositories	73
block_license_AGPL	All remote repositories	73
block_license_GPL	All remote repositories	73
block_license_LGPL	All remote repositories	73
block_no_license	All remote repositories	73
Block Released Less Than 30 Days	Selected repositories	93
guy-dry-run	Selected repositories	327
guy-warn-viral-licenses	Selected repositories	39
jml-agentic-development-lab-npm	Selected repositories	37
jml-yoitsmikeho-npm	Selected repositories	92
kushatest	pkg_types	93
mikios-test-aiextension	pkg_types	52
rodolphef-exploitability	Selected repositories	161
rodolphe-security	Selected repositories	161
rsa-block-packages-with-critical-CVEs	Selected repositories	135
rsa-immaturity-policy	Selected repositories	135
sai-block-npm-axios	Selected repositories	14
sai-curation-block-policy	Selected repositories	15
tomokim-block-policy-eol	Selected repositories	16

Remote repositories outside the Curation gate

REPOSITORY	PACKAGE TYPE	COVERAGE
hza-vscode-remote	AIEditorExtensions	Not enabled
test-vscode-remote	AIEditorExtensions	Not enabled
ai-catalog-demo-ai-catalog-demo-docker-remote	Docker	Not enabled
ai-catalog-demo-nim-dr	Docker	Not enabled
alex-alex-docker-remote	Docker	Not enabled
avi-avi-docker-remote	Docker	Not enabled
avi-ghrc-docker-remote	Docker	Not enabled
btcwallet-docker-remote	Docker	Not enabled
carm-carm-docker-remote	Docker	Not enabled
dckr-ai-ml-remote	Docker	Not enabled
dckr-base-images-remote	Docker	Not enabled
dckr-cicd-remote	Docker	Not enabled
dckr-databases-remote	Docker	Not enabled
dckr-k8s-tooling	Docker	Not enabled
dckr-observability-remote	Docker	Not enabled
dckr-security-remote	Docker	Not enabled
dckr-utilities-remote	Docker	Not enabled
docker-hamzaztest	Docker	Not enabled
docker-remote-hza	Docker	Not enabled
docker-remote-k8s-io	Docker	Not enabled
dro-release-proxy	Docker	Not enabled
dylanmo-dylanmo-docker-remote	Docker	Not enabled
gn-gn-docker-remote	Docker	Not enabled
guy-guy-docker-remote	Docker	Not enabled
guyes-guyes-docker-remote	Docker	Not enabled

Vulnerability posture

REMEDIATION READINESS

0

SLA breaches
Critical violations over 30 days

14

Fixable issues
Patch or upgrade available

0

Watch blind spots
Repos with violations, no watch

BY SEVERITY

500

500 Critical

0 High

0 Medium

0 Low

BY POLICY TYPE

500

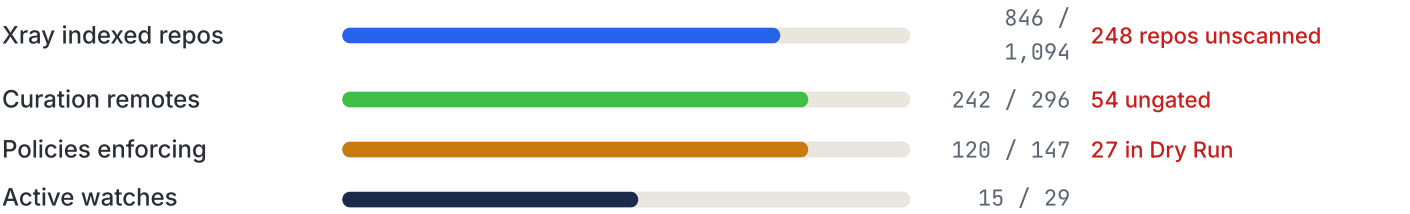
500 Security

0 Operational

0 License

Platform configuration

15 of 29 Xray watches active · 50 Xray policies (43 security, 3 license, 4 operational risk)



Top exposure

ISSUE	COMPONENT	SEVERITY	ARTIFACT HITS
XRAY-209002	—	CRITICAL	11
XRAY-515258	—	CRITICAL	10
XRAY-976252	—	CRITICAL	10
XRAY-520258	—	CRITICAL	10
XRAY-936478	—	CRITICAL	10

All findings (top 20)

ISSUE	COMPONENT	SEVERITY	ARTIFACTS
XRAY-157677	1.4.5	CRITICAL	—
XRAY-157668	1.4.5	CRITICAL	—
XRAY-157674	1.4.5	CRITICAL	—
XRAY-157669	1.4.5	CRITICAL	—
XRAY-157673	1.4.5	CRITICAL	—
XRAY-157675	1.4.5	CRITICAL	—
XRAY-60282	1.4.5	CRITICAL	—
XRAY-965334	3.1.2.RELEASE	CRITICAL	—
XRAY-157672	1.4.5	CRITICAL	—
XRAY-975911	3.1.2.RELEASE	CRITICAL	—
XRAY-965335	3.1.2.RELEASE	CRITICAL	—
XRAY-975911	3.1.2.RELEASE	CRITICAL	—
XRAY-157673	1.4.5	CRITICAL	—
XRAY-157674	1.4.5	CRITICAL	—
XRAY-157677	1.4.5	CRITICAL	—
XRAY-60282	1.4.5	CRITICAL	—
XRAY-157668	1.4.5	CRITICAL	—
XRAY-965335	3.1.2.RELEASE	CRITICAL	—
XRAY-965334	3.1.2.RELEASE	CRITICAL	—
XRAY-157675	1.4.5	CRITICAL	—

Critical issue work queue

ISSUE	COMPONENT	FIX	EXPLOIT	ENVIRONMENT	HITS	DAYS
XRAY-209002	3.1.6	unknown	unknown	—	11	4
XRAY-412242	3.9.4	unknown	unknown	—	10	4
XRAY-513454	3.9.4	unknown	unknown	—	10	4
XRAY-513994	3.9.4	unknown	unknown	—	10	4

ISSUE	COMPONENT	FIX	EXPLOIT	ENVIRONMENT	HITS	DAYS
XRAY-515258	3.9.4	unknown	unknown	—	10	4
XRAY-520258	3.9.4	unknown	unknown	—	10	4
XRAY-522886	6.11.2	unknown	unknown	—	10	4
XRAY-85679	4.2.1	unknown	unknown	—	10	4
XRAY-936478	3.9.4	available	unknown	—	10	4
XRAY-959813	4.2.1	available	unknown	—	10	4
XRAY-965738	6.11.2	unknown	unknown	—	10	4
XRAY-975816	3.9.4	unknown	unknown	—	10	4
XRAY-975955	0.21.4	available	unknown	—	10	4
XRAY-976249	3.9.4	unknown	unknown	—	10	4
XRAY-976250	3.9.4	unknown	unknown	—	10	4
XRAY-976251	3.9.4	unknown	unknown	—	10	4
XRAY-976252	3.9.4	unknown	unknown	—	10	4
XRAY-978074	3.9.4	available	unknown	—	10	4
XRAY-978088	3.9.4	available	unknown	—	10	4
XRAY-992800	3.9.4	unknown	unknown	—	10	4
XRAY-198701	3.9.4	unknown	unknown	—	9	4
XRAY-253802	3.9.4	unknown	unknown	—	9	4
XRAY-523322	3.9.4	unknown	unknown	—	9	4
XRAY-978075	3.9.4	available	unknown	—	9	4
XRAY-979649	3.9.4	available	unknown	—	9	4
XRAY-979650	3.9.4	available	unknown	—	9	4
XRAY-983975	3.9.4	available	unknown	—	9	4
XRAY-992798	3.9.4	unknown	unknown	—	9	4
XRAY-992821	3.9.4	unknown	unknown	—	9	4
XRAY-992822	3.9.4	unknown	unknown	—	9	4
XRAY-992823	3.9.4	unknown	unknown	—	9	4

ISSUE	COMPONENT	FIX	EXPLOIT	ENVIRONMENT	HITS	DAYS
XRAY-710424	6.9.11.60+dfsg-1.6+deb12u3	unknown	unknown	—	8	4
XRAY-710430	6.9.11.60+dfsg-1.6+deb12u3	unknown	unknown	—	8	4
XRAY-719925	6.9.11.60+dfsg-1.6+deb12u3	available	unknown	—	8	4
XRAY-902268	2.74.6-2+deb12u7	unknown	unknown	—	8	4
XRAY-934213	6.9.11.60+dfsg-1.6+deb12u3	unknown	unknown	—	8	4
XRAY-945966	6.9.11.60+dfsg-1.6+deb12u3	unknown	unknown	—	8	4
XRAY-945994	6.9.11.60+dfsg-1.6+deb12u3	unknown	unknown	—	8	4
XRAY-945995	6.9.11.60+dfsg-1.6+deb12u3	unknown	unknown	—	8	4
XRAY-945999	6.9.11.60+dfsg-1.6+deb12u3	unknown	unknown	—	8	4
XRAY-961927	3.0.17-1~deb12u2	unknown	unknown	—	8	4
XRAY-964342	3.11.2-6+deb12u6	unknown	unknown	—	8	4
XRAY-973469	3.7.9-2+deb12u5	unknown	unknown	—	8	4
XRAY-973474	3.7.9-2+deb12u5	unknown	unknown	—	8	4
XRAY-997641	10.11.14-0+deb12u2	available	unknown	—	8	4
XRAY-999320	3.0.17-1~deb12u2	unknown	unknown	—	8	4
XRAY-1032963	0.25.3	unknown	unknown	—	7	4
XRAY-945968	6.9.11.60+dfsg-1.6+deb12u3	unknown	unknown	—	7	4
XRAY-945969	6.9.11.60+dfsg-1.6+deb12u3	unknown	unknown	—	7	4
XRAY-946001	6.9.11.60+dfsg-1.6+deb12u3	unknown	unknown	—	7	4

LICENSE COMPLIANCE

0 license violations

OPERATIONAL RISK

0 operational violations

Prioritized remediation

01 Patch 14 critical issues with available fixes

Fixed versions already exist. These are the fastest exposure reducers.

P1

Effort: Medium

114 artifact hits

02 Index 248 repositories in Xray

23% of repos have no Xray indexing. Violations there are invisible.

P1

Effort: Medium

846/1,094 indexed

03 Remediate 500 critical violations

Assign remediation owners to the highest-hit XRAY issue IDs.

P1

Effort: High

500 critical, 0 high

04 Patch 14 critical issues with known fixes

Impact: these fixes remove 114 artifact hits without waiting for compensating controls. Next step: prioritize components in Highest-Impact Fixes.

P1

Effort: Medium

Owner: Security Operations

Due: 2026-08-07

Score: 94

05 Remediate vm2:3.9.4 (XRAY-412242, XRAY-513454, XRAY-513994 + 22 more — 239 hits)

Impact: The package vm2 before 3.9.10 are vulnerable to Arbitrary Code Execution due to the usage of prototype lookup for the We. Next step: review affected artifacts in Xray console for XRAY-412242.

P1

Effort: Medium

Owner: Security Operations

Due: 2026-08-07

Score: 98

06 Remediate debian:bookworm:libmagickcore-6.q16-6:8: (XRAY-710424, XRAY-710430, XRAY-719925 + 8 more — 86 hits)

Impact: ImageMagick is free and open-source software used for editing and manipulating digital images. Versions prior to 7.1.2-0. Next step: review affected artifacts in Xray console for XRAY-710424.

P1

Effort: Medium

Owner: Security Operations

Due: 2026-08-07

Score: 98

07 Remediate debian:bookworm:libglib2.0-bin:2.74.6-2+ (XRAY-902268, XRAY-973469, XRAY-973474 — 24 hits)

Impact: A flaw was found in GLib (Gnome Lib). This vulnerability allows a remote attacker to cause heap corruption, leading to a. Next step: review affected artifacts in Xray console for XRAY-902268.

P1

Effort: Medium

Owner: Security Operations

Due: 2026-08-07

Score: 82

08

Remediate protobufjs:6.11.2 (XRAY-522886, XRAY-965738 — 20 hits)

Impact: "protobuf.js (aka protobufjs) 6.10.0 through 7.x before 7.2.5 allows Prototype Pollution, a different vulnerability than. Next step: review affected artifacts in Xray console for XRAY-522886.

P1

Effort: Medium

Owner: Security Operations

Due: 2026-08-07

Score: 80

09

Remediate lodash:4.2.1 (XRAY-85679, XRAY-959813 — 20 hits)

Impact: Versions of lodash lower than 4.17.12 are vulnerable to Prototype Pollution. The function defaultsDeep could be tricked . Next step: review affected artifacts in Xray console for XRAY-85679.

P1

Effort: Medium

Owner: Security Operations

Due: 2026-08-07

Score: 80

10

Promote 27 Curation policies from Dry Run to Block

Dry Run policies detect but never block downloads. Promoting closes the gap immediately.

P2

Effort: Low

120 blocking, 27 Dry Run

11

Connect 54 supported remotes to Curation

These remote repositories serve packages without curation screening.

P2

Effort: Low

242/296 connected

12

Connect 53 supported remotes to the Curation gate

Impact: supported remotes can bypass policy checks today, led by Docker. Next step: connect these repositories in Curation repository settings.

P2

Effort: Low

Owner: Platform Security

Due: 2026-08-30

Score: 84

13

Extend Xray coverage to 248 unindexed repositories (23% blind spot)

Impact: 23% coverage gap means violations in 248 repos are invisible to any watch or policy. Next step: enable indexing on all remote repos via Xray → Repositories → Indexed Resources, prioritizing Docker, npm, and Maven.

P2

Effort: Medium

Owner: Platform Security

Due: 2026-08-30

Score: 80

14

Promote 27 dry-run curation policies to block mode

Impact: 27 policies are running in dry-run (audit-only). Promoting them to block mode would increase enforced gate coverage. Next step: review audit-log false-positive rate, then enable block mode in Curation policy settings.

P2

Effort: Low

Owner: Platform Security

Due: 2026-08-30

Score: 72

15

Review 14 inactive Xray watches

14 of 29 watches are not active.

P3

Effort: Low

15/29 active

Threat velocity

Baseline required. Threat velocity will be available after two validated report runs.

Weekly Security Report · solenglatest.jfrog.io · Generated 2026-07-31

Data: JFrog Xray + Curation APIs · Schema 2.0-beta